

Remote Code Execution in [berriai/litellm](#)

✓ Valid

Reported on Jun 15th 2024

Description

It allows us to add a callback function to the configuration file here.

https://github.com/BerriAI/litellm/blob/056913fd7049923a106130b02d7c29e7f312beec/litellm/proxy/proxy_server.py#L2734

```
elif key == "post_call_rules":
    litellm.post_call_rules = [
        get_instance_fn(value=value, config_file_path=config_file_path)
    ]
    verbose_proxy_logger.debug(
        f"litellm.post_call_rules: {litellm.post_call_rules}"
    )
```

The value we provide is separated at the final "." mark, and the last part is considered the function name. The remaining part is appended with the ".py" extension, and the file is imported.

<https://github.com/BerriAI/litellm/blob/056913fd7049923a106130b02d7c29e7f312beec/litellm/proxy/utils.py#L1872>

```
def get_instance_fn(value: str, config_file_path: Optional[str] = None) -> Any:
    try:
        print_verbose(f"value: {value}")
        # Split the path by dots to separate module from instance
        parts = value.split(".")

        # The module path is all but the last part, and the instance_name is the last part
        module_name = ".".join(parts[:-1])
        instance_name = parts[-1]

        # If config_file_path is provided, use it to determine the module spec and
        if config_file_path is not None:
            directory = os.path.dirname(config_file_path)
            module_file_path = os.path.join(directory, *module_name.split("."))
            module_file_path += ".py"

            spec = importlib.util.spec_from_file_location(module_name, module_file_path)
            if spec is None:
                raise ImportError(
                    f"Could not find a module specification for {module_file_path}"
                )
```

```

    )
    module = importlib.util.module_from_spec(spec) # type: ignore
    spec.loader.exec_module(module) # type: ignore
else:
    # Dynamically import the module
    module = importlib.import_module(module_name)

    # Get the instance from the module
    instance = getattr(module, instance_name)

    return instance
except ImportError as e:
    #...

```

When a chat response is received, it is given to this callback function, and the function processes this data.

<https://github.com/BerriAI/litellm/blob/056913fd7049923a106130b02d7c29e7f312beec/litellm/utils.py#L2818>

```

def post_call_rules(self, input: Optional[str], model: str) -> bool:
    if input is None:
        return True
    for rule in litellm.post_call_rules:
        if callable(rule):
            decision = rule(input) # !! this is where we want to reach
            if type(decision) == bool:
                if decision is False:
                    raise litellm.APIResponseValidationError(message="LLM Respo
            elif type(decision) == dict:
                decision_val = decision.get("decision", True)
                decision_message = decision.get(
                    "message", "LLM Response failed post-call-rule check"
                )
                if decision_val is False:
                    raise litellm.APIResponseValidationError(message=decision_m
    return True

```

Proof of Concept

We set the system method in the os file as a callback, and now all LLM responses will go to this function.

```
curl "http://localhost:4000/config/update" -X POST -H "Authorization: Bearer sk-123"
```

We convince the LLM to return the command we want to execute.

```
curl -X 'POST' 'http://localhost:4000/engines/gpt-3.5-turbo/chat/completions' -H 'a
```

Impact

Allows the attacker to execute malicious code, gaining full control over the system.

⚙️ We are processing your report and will contact the **berriai/litellm** team within 24 hours. 2 years ago

✉️ We have contacted a member of the **berriai/litellm** team and are waiting to hear back 2 years ago



✎️ **Dan McInerney** modified the Severity from Critical (9.8) to High (8.8) 2 years ago

✉️ We have sent a follow up to the **berriai/litellm** team. We will try again in 4 days. 2 years ago

✉️ We have sent a second follow up to the **berriai/litellm** team. We will try again in 7 days. 2 years ago

✉️ We have sent a third follow up to the **berriai/litellm** team. We will try again in 14 days. 2 years ago

✉️ We have sent a fourth follow up to the **berriai/litellm** team. We will send a final notification 48 hours before report publication. 2 years ago



✎️ **mvlttt** modified the report 2 years ago

⚙️ This report has now been passed to internal triage and should be resolved within 14 days. 2 years ago



✎️ **Marcello** modified the Severity from Critical (9.8) to High (8.8) 2 years ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



✓ **Marcello** validated this vulnerability 2 years ago

\$ **mvlttt** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7



CVE-2024-6825 assigned to this report. 2 years ago

✉️ We have notified the **berriai/litellm** maintainers about this report in their weekly follow-up a year ago

⚠ We have sent a warning to the **berriai/litellm** team to inform them that this report will be published in 48 hours a year ago

🔄 This vulnerability has now been published a year ago

🏆 CVE-2024-6825 has now been published 10 months ago



Krish Dholakia commented 7 months ago

Maintainer

- this issue is now fixed - <https://github.com/BerriAI/litellm/commit/441c7275ed2715f47650a7c2e525055c804073a9>



👁 A **berriai/litellm** maintainer has acknowledged this report 7 months ago



✓ Krish Dholakia marked this as fixed in **v1.65.4.dev6** with commit **441c72** 7 months ago

\$ Ishaan Jaff has been awarded the fix bounty ✓



Krish Dholakia commented 7 months ago

Maintainer

- it looks like the "Attacker" is also the proxy admin

```
curl "http://localhost:4000/config/update" -X POST -H "Authorization: Bearer sk-1234"
```

the `/config/update` endpoint is a protected endpoint, only accessible to the proxy admin.

So, if the admin is executing arbitrary code it is **not** a vulnerability.

[Sign in](#) to join this conversation

CVE
CVE-2024-6825
Published

Vulnerability Type
CWE-94: Code Injection

Severity
High (8.8)

Attack vector	Network
Attack complexity	Low
Privileges required	Low
User interaction	None
Scope	Unchanged
Confidentiality	High
Integrity	High
Availability	High

[Open in visual CVSS calculator](#) ↗

Registry

Pypi

Affected Version

1.40.12

Visibility

Public

Status

Fixed

Disclosure Bounty

\$750

Fix Bounty

\$187.5

Found by



mvlttt

@mvlttt

MIDDLEWEIGHT



Fixed by



Ishaan Jaff

@ishaan-jaff

UNPROVEN



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)